Переводы и история операций

Отчёт модели угроз RiskFr

18 угроз · 4 основных элемента · 6 потоков данных · 3 границы доверия

Область оценки

Модель банковского сервиса переводов и истории операций. Основа анализа — исходная версия 4903ad261d30bc2d1171e455f916e445a7963b4e. После исправления импортов и добавления сборки проведена проверка работающего API: 47 HTTP-запросов. Подмена личности подтверждена; SQL-инъекция не обнаружена. Условия внешнего развёртывания оценены по исходному docker-compose.yml.

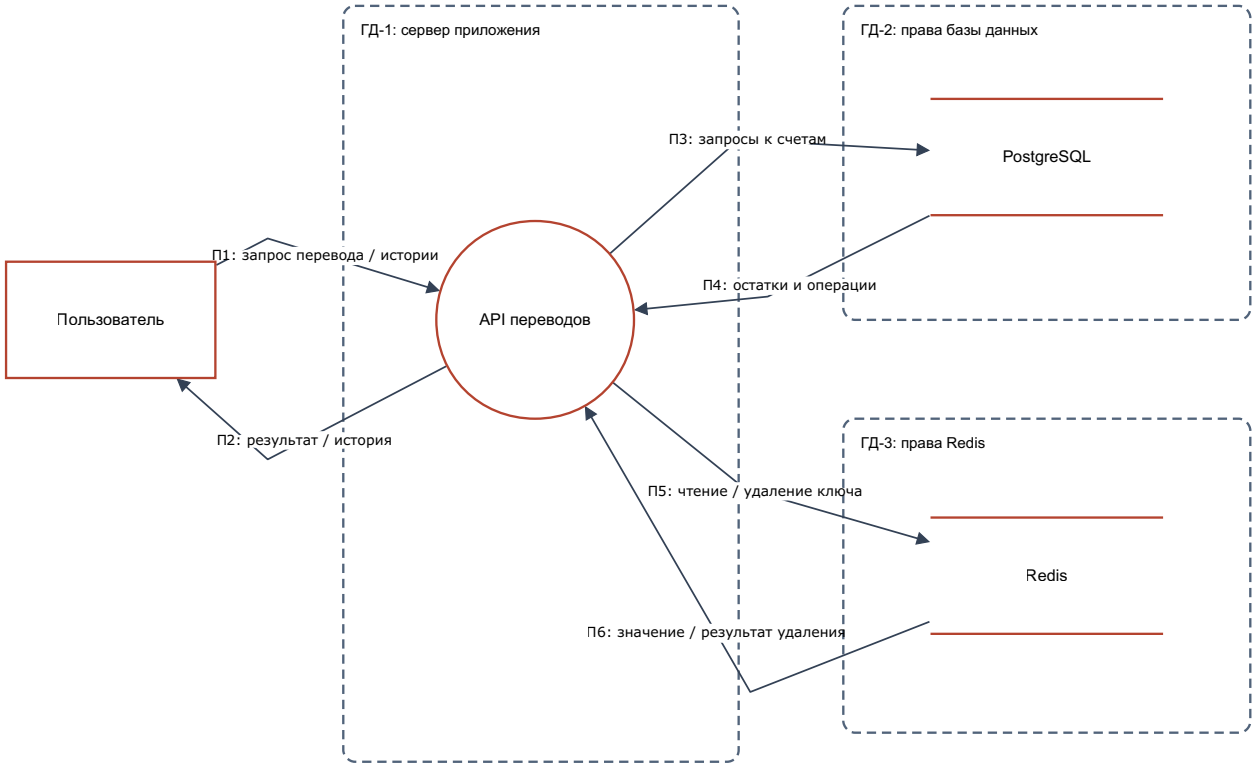
Владелец: служба информационной безопасности (учебная модель).

Сводка из Threat Dragon

Всего угроз	18
Снижены имеющимися мерами	1
Открытые угрозы	17
Открытые: критические	4
Открытые: высокие	9
Открытые: средние	4
Открытые: низкие	0

SQL-инъекция (У16) ограничена существующей параметризацией. У01, У04 и У05 имеют общую причину — отсутствие проверки личности; их последствия оцениваются совместно.

Диаграмма потоков данных



ГД-1 отделяет недоверенного клиента от приложения; ГД-2 и ГД-3 — полномочия доступа к PostgreSQL и Redis. Пунктиром показаны логические границы, а не подтверждённая сетевая сегментация. Публикация портов PostgreSQL и Redis в исходном файле развёртывания создаёт дополнительные пути доступа.

Направление стрелки показывает передачу запроса или ответа. PostgreSQL и Redis не становятся доверенными только из-за нахождения во внутренней сети.

Пользователь (внешняя сущность)

Клиент банка или нарушитель с доступом к HTTP-интерфейсу. Устройство и переданные заголовки не считаются доверенными.

У01. Подмена личности владельца счёта

S — подмена личности · Критическая · Открыта

Сценарий и основания

Подмена X-User-Id позволяет представиться владельцем счёта. get_current_user_id преобразует строку в число без проверки личности. На учебном стенде заголовок со значением 1 открыл историю владельца 1 и позволил выполнить перевод с его счёта. app/security.py:3-13; http-behaviour.json/identity_spoofing. Вероятность: 3/3; ущерб: 3/3; оценка: 9/9.

Меры снижения риска

Код: проверять подписанный токен, срок и назначение, получать идентификатор только из проверенных утверждений. Архитектура: общий доверенный узел проверки личности, закрытый прямой доступ к API. Процесс: отрицательные проверки подмены личности при каждом изменении.

У02. Раскрытие истории на клиентском канале

I — раскрытие информации · Высокая · Открыта

Сценарий и основания

История содержит счета, суммы и время операций. HTTP без описанного TLS допускает чтение ответов наблюдателем сети. Внешнее завершение TLS возможно, но не представлено в поставке. docker-compose.yml:23-29; app/main.py:18-34. Вероятность: 2/3; ущерб: 3/3; оценка: 6/9.

Меры снижения риска

Инфраструктура: TLS на внешнем соединении и проверка сертификатов; код: не включать чувствительные данные в лишние ответы; процесс: проверять конфигурацию внешнего соединения перед выпуском.

У03. Оспаривание денежного перевода

R — отказ от авторства · Высокая · Открыта

Сценарий и основания

Клиент может отрицать операцию: запись transactions хранит счета и сумму, но не подтверждённого субъекта, уникальный идентификатор запроса и результат проверки доступа. Обычная строка перевода не заменяет защищённый журнал действий. app/db.py:23-29. Вероятность: 2/3; ущерб: 3/3; оценка: 6/9.

Меры снижения риска

Код: фиксировать подтверждённого субъекта, время и идентификатор запроса. Инфраструктура: защищённый отдельный журнал с ограничением изменений. Процесс: установить срок хранения и порядок расследования.

API переводов (процесс)

FastAPI: POST /transfer, GET /transactions. После исправления импортов API запущен на учебном стенде. Результаты HTTP-проверки сохранены в http-behaviour.json.

У04. Чтение чужой истории через подмену идентификатора

I — раскрытие информации · Высокая · Открыта

Сценарий и основания

После подмены X-User-Id сервер возвращает исходящие операции другого владельца. Условие a.owner_user_id=$1 присутствует, но значение $1 берётся из неподтверждённого заголовка. Проверено через GET /transactions. app/crud.py:43-66; app/security.py:11; http-behaviour.json/identity_spoofing. Вероятность: 3/3; ущерб: 3/3; оценка: 9/9.

Меры снижения риска

Код: объектная авторизация по проверенному субъекту; не принимать идентификатор владельца как доказательство полномочий. Процесс: проверки запрета чтения чужих данных при неизменном сеансе. Не считать случайный идентификатор заменой авторизации.

У05. Перевод средств от имени другого клиента

E — превышение полномочий · Критическая · Открыта

Сценарий и основания

При заголовке владельца 2 перевод со счёта 1 запрещён с кодом 403. Замена заголовка на 1 позволяет выполнить тот же перевод. Проверка принадлежности счёта зависит от значения, которое выбирает клиент. Это следствие У01. app/crud.py:5-16; http-behaviour.json/identity_spoofing. Вероятность: 3/3; ущерб: 3/3; оценка: 9/9.

Меры снижения риска

Код: связывать владельца счёта с проверенным сеансом и проверять разрешение каждой операции. Архитектура: отделить проверку личности от принятия денежного распоряжения; для рискованных операций предусмотреть дополнительное подтверждение.

У06. Одновременное списание сверх остатка

T — изменение данных · Критическая · Открыта

Сценарий и основания

Два перевода читают один остаток до обновления и оба проходят проверку. Обновление не содержит условия достаточности средств; блокировки SELECT FOR UPDATE и ограничения balance_cents>=0 нет. Получено -300000 копеек после двух переводов по 400000 с остатка 500000. app/crud.py:22-33; app/db.py:19; behaviour.json/concurrent_transfers. Вероятность: 3/3; ущерб: 3/3; оценка: 9/9.

Меры снижения риска

Код: атомарное условное списание с проверкой числа строк или блокировка счетов в фиксированном порядке в одной транзакции; корректно обрабатывать конфликт. База: ограничение неотрицательного остатка при запрете овердрафта. Процесс: параллельные проверки сохранения денежных инвариантов.

У07. Повторное списание после ошибки Redis

T — изменение данных · Критическая · Открыта

Сценарий и основания

Перевод уже зафиксирован в PostgreSQL, когда выполняется DEL Redis. Ошибка Redis выдаёт исключение после фиксации; повтор запроса создаёт второй перевод, поскольку ключа защиты от повторного исполнения нет. Подтверждено двумя записями вместо одной. app/crud.py:20-41; behaviour.json/retry_after_redis_failure. Вероятность: 3/3; ущерб: 3/3; оценка: 9/9.

Меры снижения риска

Код: ключ однократного исполнения, связанный с субъектом и содержимым запроса, с уникальным ограничением и сохранением результата в той же транзакции. Архитектура: очередь отложенных действий в базе для обновления кеша; ошибка кеша не должна делать результат перевода неоднозначным. Процесс: проверки повторов и отказов зависимостей.

У08. Истощение ресурсов запросами истории

D — отказ в обслуживании · Средняя · Открыта

Сценарий и основания

Параметры limit и search ограничены, но частота запросов не ограничена; преобразование id в текст и ILIKE могут приводить к просмотру множества строк. Пул базы ограничен пятью соединениями. Степень влияния требует нагрузочной проверки. app/main.py:21-22; app/crud.py:61; app/db.py:9. Вероятность: 2/3; ущерб: 2/3; оценка: 4/9.

Меры снижения риска

Инфраструктура: ограничения частоты и числа одновременных запросов. Код: подходящие индексы, постраничная выдача и сроки исполнения. Процесс: проверить предельную нагрузку на объёме данных, близком к рабочему.

PostgreSQL (хранилище)

Счета, владельцы, остатки в копейках и операции. Публикация 5432 и известные реквизиты указаны в docker-compose.yml. Доступность из Интернета зависит от внешних сетевых правил.

У09. Чтение данных через опубликованный порт

I — раскрытие информации · Высокая · Открыта

Сценарий и основания

Файл развёртывания публикует 5432 на всех интерфейсах и содержит известные реквизиты postgres/postgres. При отсутствии внешнего сетевого ограничения возможно прямое чтение банковских данных. Публикация порта подтверждена; доступ из Интернета не проверялся. docker-compose.yml:7-11. Вероятность: 2/3; ущерб: 3/3; оценка: 6/9.

Меры снижения риска

Инфраструктура: исключить внешнюю публикацию базы и разрешить доступ только серверу приложения; заменить реквизиты и хранить их вне репозитория. Процесс: проверять открытые порты при выпуске.

У10. Изменение денежных данных привилегированной ролью

T — изменение данных · Высокая · Открыта

Сценарий и основания

Приложение использует роль postgres с широкими правами, указанную в строке подключения. Компрометация процесса приложения может дать возможность произвольно менять остатки и историю. docker-compose.yml:7-8,23; app/db.py:15-29. Вероятность: 2/3; ущерб: 3/3; оценка: 6/9.

Меры снижения риска

База: отдельная роль с минимальными разрешениями; выполнение изменений схемы отдельной ролью. Инфраструктура: изоляция сетевого доступа и секретов. Процесс: контроль привилегий и независимая сверка денежных операций.

У11. Утрата базы или непригодный резервный экземпляр

D — отказ в обслуживании · Высокая · Открыта

Сценарий и основания

В поставке есть том pgdata, но нет описания резервного копирования и проверок восстановления. Том не является резервной копией. Повреждение или удаление данных может остановить переводы и историю; отсутствие внешних копий не утверждается. docker-compose.yml:12-13,33-34. Вероятность: 2/3; ущерб: 3/3; оценка: 6/9.

Меры снижения риска

Инфраструктура: изолированные резервные копии и восстановление на момент времени. Процесс: согласовать допустимые потери данных и время восстановления, регулярно выполнять учебное восстановление и проверять целостность.

Redis (хранилище)

Чтение ключей tx:{user_id}:{limit}:{search}, удаление tx:{user_id}. Запись результатов в кеш отсутствует. Получение непустого значения возвращает пустую историю.

У12. Подмена признака наличия истории

T — изменение данных · Средняя · Открыта

Сценарий и основания

При непустом значении ключа tx:{user_id}:{limit}:{search} функция возвращает [], игнорируя историю базы. Внедрённый извне ключ скрывает операции. Redis опубликован без указанной проверки доступа; само приложение ключи не записывает. app/crud.py:45-48; docker-compose.yml:15-18; behaviour.json/redis_history_suppression. Вероятность: 2/3; ущерб: 2/3; оценка: 4/9.

Меры снижения риска

Инфраструктура: закрытая сеть, списки разрешённых команд и проверка доступа Redis. Код: проверять формат кешированных данных и возвращать действительные операции либо обращаться к базе. Процесс: отрицательные проверки повреждённого кеша.

У13. Отказ истории при недоступности кеша

D — отказ в обслуживании · Высокая · Открыта

Сценарий и основания

GET Redis выполняется до обращения к базе без обработки отказа. Недоступность Redis может остановить чтение истории даже при исправной PostgreSQL. app/crud.py:44-50. Вероятность: 2/3; ущерб: 2/3; оценка: 4/9.

Меры снижения риска

Код: ограничить время ожидания и предусмотреть обращение к базе при отказе кеша. Инфраструктура: ограничить ресурсы Redis и обеспечить наблюдение за отказами. Процесс: проверки отключения зависимости.

У14. Раскрытие идентификаторов и параметров поиска

I — раскрытие информации · Средняя · Открыта

Сценарий и основания

Формат ключа содержит user_id, limit и поисковую строку. Если ключи создаёт другой компонент, прямой доступ к Redis раскрывает эти сведения. Запись ключей данным приложением не обнаружена; сценарий условный. app/crud.py:45; docker-compose.yml:15-18. Вероятность: 2/3; ущерб: 2/3; оценка: 4/9.

Меры снижения риска

Инфраструктура: ограничить доступ и сетевой обмен. Код: минимизировать чувствительные данные в ключах. Процесс: определить владельца записи, срок хранения и допустимый состав кеша.

П1: запрос перевода / истории (поток данных)

HTTP: X-User-Id; from_account_id, to_account_id, amount_cents; limit, search. Пересекает ГД-1. TLS и внешняя проверка личности в исходной поставке не описаны.

У15. Изменение денежного распоряжения в пути

T — изменение данных · Высокая · Открыта

Сценарий и основания

Если внешнее соединение остаётся HTTP, посредник может менять счета, сумму или заголовок пользователя. В репозитории нет описанного завершения TLS. Это условие архитектуры, а не доказательство атаки на работающий сервер. docker-compose.yml:25-26. Вероятность: 2/3; ущерб: 3/3; оценка: 6/9.

Меры снижения риска

Инфраструктура: TLS и запрет незашифрованных денежных запросов. Код: связывать подтверждение операции с конкретными счётом получателя и суммой. Процесс: проверять отсутствие обходного незашифрованного пути.

П2: результат / история (поток данных)

Идентификатор перевода, статусы ошибок и история операций. Пересекает ГД-1.

П3: запросы к счетам (поток данных)

Параметризованные SELECT, UPDATE, INSERT; одна транзакция для изменения остатков и записи перевода. Пересекает ГД-1 и ГД-2.

У16. SQL-инъекция при попадании ввода в текст запроса

T — изменение данных · Высокая · Снижена имеющейся мерой

Сценарий и основания

SQL-инъекция не подтверждена. В текст запроса подставляется внутренний счётчик i; search, limit и user_id передаются параметрами asyncpg. Проверены SQL-строки в поиске, заголовке, пределе выдачи и полях перевода. Данные базы после проверок не изменились. app/crud.py:58-66; http-behaviour.json/sql_injection. Вероятность: 1/3; ущерб: 3/3; оценка: 3/9.

Меры снижения риска

Существующая защита: параметры $1…$n. Сохранять разделение текста запроса и значений. При изменении SQL повторять проверку правил и HTTP-запросы с обычными и специально составленными значениями.

П4: остатки и операции (поток данных)

Ответы базы: признак владельца, остатки, строки истории. Пересекает ГД-2 и ГД-1.

У17. Перехват соединения с базой

I — раскрытие информации · Высокая · Открыта

Сценарий и основания

Настройки не требуют проверки TLS PostgreSQL. При доступе нарушителя к внутреннему сетевому пути возможен перехват чувствительных данных; состояние защиты внешней инфраструктуры неизвестно. app/db.py:9; docker-compose.yml:23. Вероятность: 2/3; ущерб: 3/3; оценка: 6/9.

Меры снижения риска

Инфраструктура: изолировать сеть, настроить проверку сертификата сервера базы, ограничить сетевые разрешения. Процесс: проверить эффективные параметры соединения в целевой среде.

П5: чтение / удаление ключа (поток данных)

GET tx:{user_id}:{limit}:{search}, DEL tx:{user_id}. SET в приложении отсутствует. Пересекает ГД-1 и ГД-3.

У18. Несогласованное удаление записей кеша

T — изменение данных · Средняя · Открыта

Сценарий и основания

История читается по составному ключу tx:user:limit:search, а перевод удаляет только tx:user. Созданный ранее составной ключ сохраняется после перевода. Для текущего кода это воспроизведено с отдельно созданным ключом; штатная запись кеша отсутствует. app/crud.py:40,45; behaviour.json/redis_invalidation. Вероятность: 2/3; ущерб: 2/3; оценка: 4/9.

Меры снижения риска

Код: определить единый формат ключей и версию истории, учитывать оба счёта перевода. Архитектура: обновлять кеш после зафиксированной операции надёжным отложенным действием. Процесс: согласовать контракт чтения и записи между компонентами.

П6: значение / результат удаления (поток данных)

Значение ключа, подтверждение удаления или ошибка соединения. Пересекает ГД-3 и ГД-1.